

Why Runtime Scanning Is Too Late for Your CI/CD Supply Chain Security

CyberIntel Threat Advisory - automated analysis of source reporting: affected systems, actor attribution, and recommended actions.

INTELLIGENCE SNAPSHOT

Issued by	CyberIntel
Date	16 June 2026
Source	thehackernews
Region	Unknown
Threat Level	CRITICAL
Focus	Supply-chain compromise
Motivations	Unknown
Prominent Actors	-
Primary Tactics	Obfuscated and environmentally triggered payloads, typosquatting attacks, exploiting compressed window between vulnerability disclosure and active exploitation
Affected Systems / Vendors	Linux distributions, CI/CD environments, build systems, artifact repositories, AI coding assistants
CVEs	None identified
Reference	https://thehackernews.com/expert-insights/2026/06/why-runtime-scanning-is-too-late-for.html
Classification	For Authorised Recipients

Executive Summary

The current detection-only security posture in CI/CD environments is flawed, as it focuses on monitoring runtime alerts rather than governing the point of ingestion where code enters the pipeline. This approach leads to a significant resource drain, with security teams spending hours on manual research, triage, and remediation, and a high cost of late detection, including breach notification obligations, extended engineering downtime, and regulatory inquiry. The industry average mean time to remediate a critical CVE is over 60 days, leaving organizations exposed to attacks. Modern software supply chain attacks are engineered to bypass signature-based runtime scanners, using obfuscated and environmentally triggered payloads, typosquatting attacks, and exploiting the compressed window between vulnerability disclosure and active exploitation. The assumption that a secure perimeter exists between the internet and internal pipeline is no longer valid, as build systems, CI/CD runners, artifact repositories, and AI coding assistants are connected to public registries, making the dependency resolution chain the primary attack surface. Shifting to the point of ingestion, where dependencies are downloaded and become the organization's problem to manage, is critical, as this is where malicious packages execute their payload, often during the build phase, before testing infrastructure, staging environments, or runtime scanners can engage. The financial difference between catching a malicious package at the point of ingestion and remediating a compromised cluster is significant, with the latter costing breach notification obligations, extended engineering downtime, regulatory inquiry, and customer trust that takes years to rebuild. The inevitable failure of detection-only security postures requires a mindset shift from monitoring what is running to governing what enters the pipeline, applying governance infrastructure to the moment of

ingestion, and verifying that packages are not compromised, match the requested version, and comply with organizational policies.

■ **THREAT LEVEL: CRITICAL**

FOCUS: SUPPLY-CHAIN COMPROMISE

Critical Infrastructure & Notable Sector Impacts

Sector	Targeted Entity / System	Actor	Impact / Method
Software development	CI/CD pipelines	-	Malicious packages executing payloads during build phase

Initial Access Vectors & TTPs

Threat Actor	Documented Attack Vectors & TTPs
General	Obfuscated and environmentally triggered payloads, typosquatting attacks, exploiting compressed window between vulnerability disclosure and active exploitation

Detection Measures & Mitigation Strategy

- ✓ **Vulnerability scanning.** Scanning for known vulnerabilities in dependencies, but may not detect obfuscated or environmentally triggered payloads
- ✓ **License compliance checks.** Verifying that dependencies comply with organizational license policies, but may not detect malicious packages
- ✓ **SBOM generation.** Generating a software bill of materials to track dependencies, but may not detect malicious packages
- ✓ **Code review.** Reviewing code for security vulnerabilities, but may not detect malicious packages

CyberIntel Strategic Recommendations

- ✓ **Shift to point of ingestion governance.** Apply governance infrastructure to the moment of ingestion, verifying that packages are not compromised, match the requested version, and comply with organizational policies
- ✓ **Implement dependency resolution chain governance.** Govern the dependency resolution chain, ensuring that dependencies are trusted and verified before entering the pipeline
- ✓ **Use complementary security controls.** Use complementary security controls, such as runtime scanners, to detect and respond to malicious activity, but recognize their limitations
- ✓ **Continuously monitor and update dependencies.** Continuously monitor and update dependencies to ensure that known vulnerabilities are addressed and malicious packages are detected and removed

Disclaimer & Classification

This advisory is generated by CyberIntel through automated analysis of publicly available source reporting and is provided for situational awareness only. It does not constitute legal, operational, or security advice. CyberIntel makes no warranty as to the completeness or accuracy of the underlying source material. Recipients should independently verify findings before acting on them.

Classification: For Authorised Recipients Only | **Distribution:** Internal use; do not forward outside the intended recipient organisation. |

Contact: intel@cyberintel.local